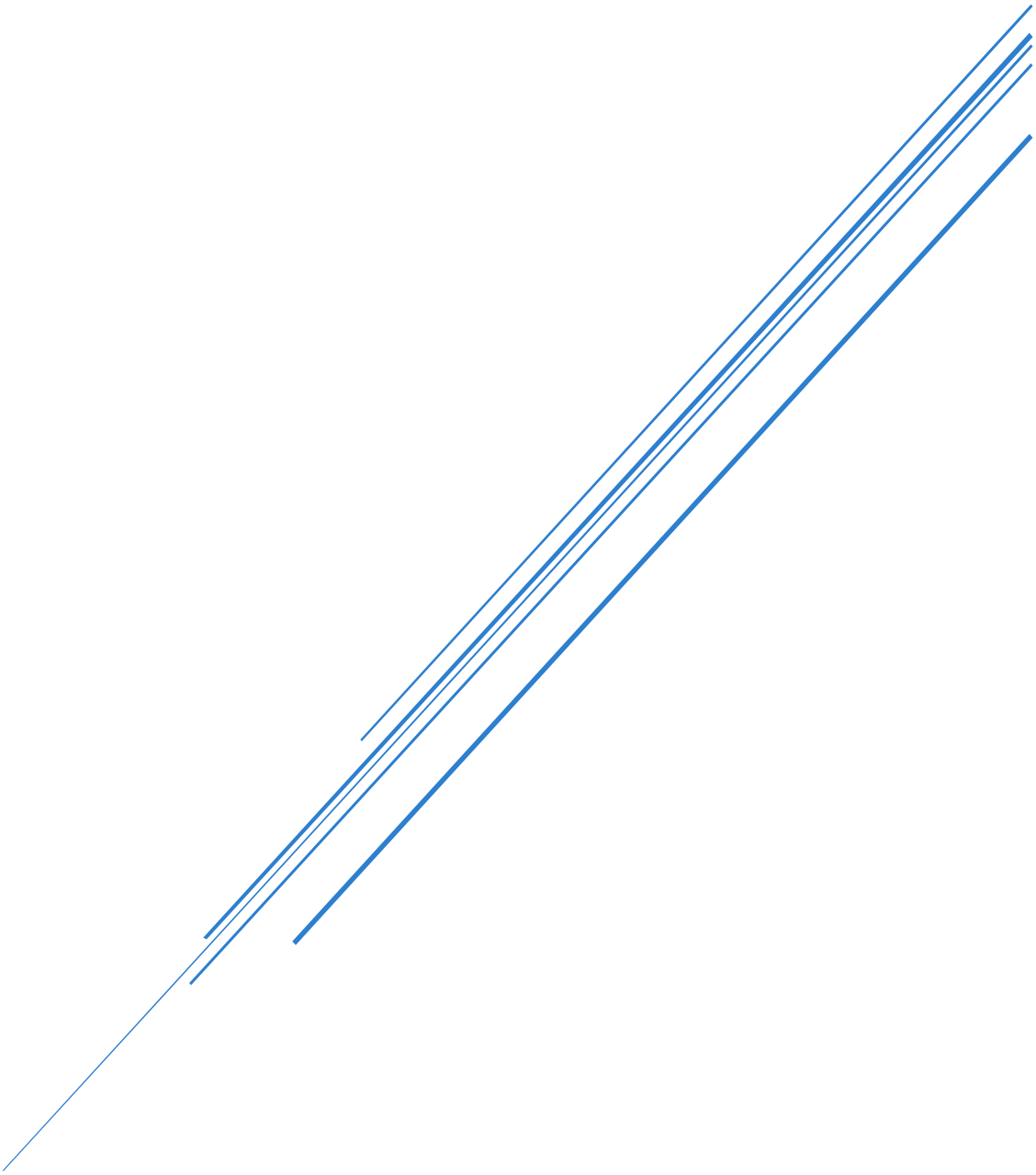
CIBERSEGURIDAD

Práctica UT1. Identificar para proteger



Daniel Núñez Uribe

11/10/2026

UT1 – Práctica 1.

Parte A · Diagnóstico del escenario documentado

A.1. El servidor de ficheros

A.1.1

Identifica todas las vulnerabilidades del escenario y construye una tabla con estas columnas: vulnerabilidad, ámbito (sistema operativo, red o aplicación y gestión de accesos), amenaza que la puede explotar, mecanismo que usaría el atacante e impacto sobre la confidencialidad, la integridad y la disponibilidad, justificando cada principio afectado.

Vulnerabilidad	Ámbito	Amenaza	Mecanismo	Impacto
La cuenta admin, que usamos todos para administrar el servidor, tiene una contraseña fácil de recordar y puede hacer sudo sin volver a escribirla	S.O	Logins indeseados que permiten ejecutar comandos con permisos elevados sobre el sistema.	Login a través del acceso SSH abierto o de la red WIFI con protocolo antiguo.	**Confidencialidad**: Acceden a un servidor de ficheros con los datos de los empleados en las nóminas. **Integridad**: Con acceso al root pueden modificar los documentos a voluntad. **Disponibilidad**: Con acceso al root pueden modificar el funcionamiento del sistema o dejarlo inservible.
El Servidor no se actualiza desde 2023	S.O	Indetección de malware y exploits de vulnerabilidades de sistema	Troyano que a través del S.O desactualizado se aproveche y ejecute scripts.	**Confidencialidad**: Posibilidad de ejecutar DQL sobre SQL y ficheros de nóminas. **Integridad**: Posibilidad de ejecutar DML sobre SQL y ficheros de nóminas. **Disponibilidad**: Pueden tirar el sistema entero desde las vulnerabilidades.
Tiene activo el sistema FTP aunque nadie lo use	Redes	FTP sin cifrar y en desuso lo que permitiría acceso a los ficheros del servidor.	Acceso a los ficheros del servidor con credenciales robadas o a través de un insider	**Confidencialidad**: Acceso ilimitado a los ficheros del servidor compartidos en FTP. **Integridad**: Permitiría la subida y modificación de los archivos. **Disponibilidad**: Pueden eliminar los archivos de las nóminas.
La carpeta de nóminas está compartida en red sin pedir usuario	Redes	Acceso externo a la carpeta	Acceso desde la propia red a la carpeta, al no necesitar login, con acceder a la red tendrían acceso	**Confidencialidad**: Acceden a los datos de los empleados en las nóminas. **Integridad**: Permitiría la modificación de los datos de las nóminas

			completo	**Disponibilidad**: Pueden eliminar los archivos de las nóminas.
El SSH está abierto a internet para quien teletrabaja	Redes	Accesos indeseados con credenciales robadas o de insiders.	Login sin necesidad de VPN lo que facilita que insiders o tras robo de credenciales accedan al servidor	**Confidencialidad**: Acceso a todos los datos del servidor, incluidos los de los empleados. **Integridad**: Permitiría la modificación de los datos de las nóminas y el resto de ficheros. **Disponibilidad**: Pueden eliminar los archivos del servidor
La WIFI de la oficina sigue con cifrado WEP porque el router es antiguo	Redes	Accesos indeseados con credenciales robadas u obtención de tráfico de red.	Captura del tráfico, o acceso a la red, a través de protocolo anticuado	**Confidencialidad**: Acceso a todos los datos del servidor, incluidos los de los empleados. **Integridad**: Permitiría la modificación de los datos de las nóminas y el resto de ficheros. **Disponibilidad**: Pueden eliminar los archivos del servidor.

A.1.2

Señala qué vulnerabilidades se combinan entre sí para agravar el riesgo. Por ejemplo, ¿qué ocurre si coinciden el SSH abierto a Internet, la contraseña débil y el sudo sin contraseña?

Las combinaciones que encuentro más peligrosas son:

- Wifi con cifrado WEP + Cuenta de admin con contraseña fácil y sudo:

Esta combinación permitiría el acceso total al servidor de ficheros una vez que se obtengan los credenciales mediante escucha de la red wifi.

- FTP Desactualizado + Servidor no actualizado:

Esta combinación podría permitir al atacante colocar troyanos directamente en el servidor sin necesidad de descargas de ningún tipo.

- SSH abierto a internet + Cuenta de admin con contraseña fácil y sudo:

Esta combinación permitiría el acceso remoto al servidor, con cuenta de administración y ejecución elevada de comandos. Puede ser fatal si su objetivo es el robo de información y la terminación del servicio ya que imagino que este servidor de ficheros mantiene conexiones con los otros dos, ya sea sirviendo ficheros de recursos al aplicativo, o a través de bases de datos, y además sirviendo las nóminas al equipo de contabilidad. Si existen conexiones entre los servidores, con esta combinación, un atacante podría acceder desde cualquier parte del mundo, no dejar rastro y robar toda la información además de inutilizar los servicios.

A.1.3

Elige la vulnerabilidad que corregirías en primer lugar y justifícalo en un párrafo, razonando en términos de probabilidad de explotación e impacto.

En primer lugar corregiría el acceso SSH a través de internet, si bien el resto de vulnerabilidades también son críticas a su respecto, considero que, corregir la exposición del servidor a toda la red global sin el uso de VPNs nominales de ningún tipo, es lo más prioritario ya que es la que más superficie de ataque presenta.

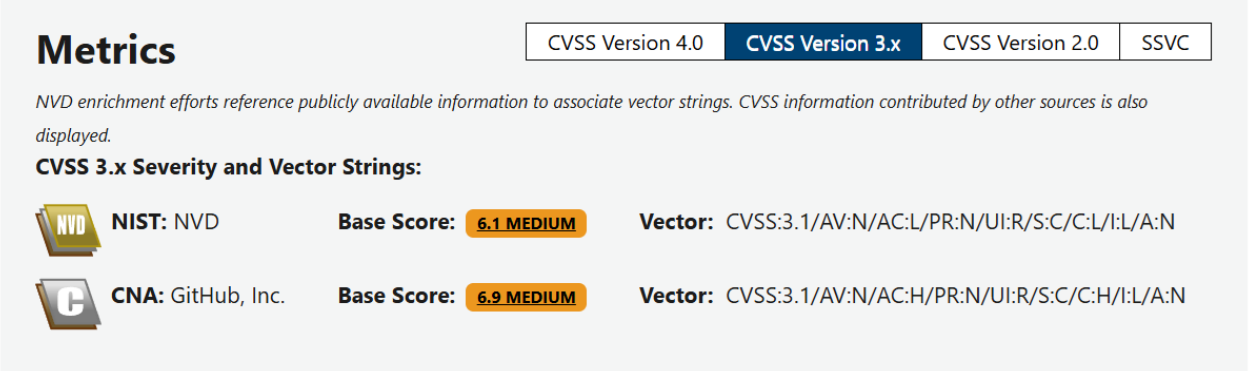
A.2 Vulnerabilidades catalogadas

A.2.1

Para cada CVE, consulta una fuente oficial (NVD o INCIBE-CERT) y anota su puntuación CVSS, el vector, el nivel de gravedad y la fuente exacta de la puntuación. Si encuentras puntuaciones distintas según la fuente, anótalas y explica a qué puede deberse.

Identificador	Puntuación CVSS	Vector	Gravedad	Fuente
CVE-2017-0144	**V3: 8,8**	Red	ALTA	NVD
CVE-2021-41773	**V3: 9.2**	Red	CRÍTICA	NVD
CVE-2020-11023	**V3: 6,1**	Red	MEDIA	NVD
CVE-2024-6387	**V3 8,1**	Red	ALTA	NVD

Sí que detecto algunas diferencias en la puntuación entre organizaciones, por ejemplo, para el identificador **CVE-2020-11023** veo dos puntuaciones ligeramente diferentes, dadas por el NIST y por GitHub



Supongo que estas diferencias se ubican en el enfoque determinado, los intereses y el conocimiento de cada una, al final el NIST está enfocado específicamente en evaluar la criticidad general de la vulnerabilidad (En este caso de cross scripting en jquery) mientras que github, que aloja este tipo de código entre otros, seguramente tenga un conocimiento más detallado y por eso lo haya evaluado por encima.

Además veo en el resumen de la derecha que la complejidad de ataque difiere entre ambos, donde NIST le da AC:L (Low) GitHub le da AC:H (High). Lo cual me confunde un poco porque entendería que un ataque de complejidad más alta debería tener una puntuación más baja. Pero supongo que el escenario particular de que alguien aproveche realmente esta vulnerabilidad sería especialmente dañino para GitHub y de ahí la mayor puntuación.

A.2.2

Interpreta el vector CVSS de dos de las vulnerabilidades: qué significan los valores de vector de ataque, complejidad, privilegios requeridos e interacción del usuario, y cómo influyen en la probabilidad de explotación.

CVE-2017-0144:

El valor del vector de ataque indica el tipo de conectividad requerida para explotar la vulnerabilidad. En este caso, “Network”, donde un atacante podría aprovecharse de esta para atacar incluso remotamente.

La complejidad indica la especificidad o dificultad de obtener los requisitos y cumplir las condiciones para que el ataque pueda efectuarse, en este caso, es “baja”.

Los Privilegios requeridos indican el nivel de acceso requerido para efectuar el ataque, desde ninguno, es decir, el atacante no necesita privilegios de ningún tipo hasta permisos elevados, cuentas de administrador etc. En este caso, es “Bajos”

La Interacción del usuario define si la vulnerabilidad requiere primero de la acción de un usuario interno que use el sistema para que se abra la puerta al ataque, ya sea clicando un enlace en un mail, descargando un archivo etc. En este caso es “Ninguna”

CVE-2021-41773:

El valor del vector de ataque indica el tipo de conectividad requerida para explotar la vulnerabilidad. En este caso, Network, donde un atacante podría aprovecharse de esta para atacar incluso remotamente.

La complejidad indica la especificidad o dificultad de obtener los requisitos y cumplir las condiciones para que el ataque pueda efectuarse, en este caso, es baja.

Los Privilegios requeridos indican el nivel de acceso requerido para efectuar el ataque, desde ninguno, es decir, el atacante no necesita privilegios de ningún tipo hasta permisos elevados, cuentas de administrador etc. En este caso, es "Ninguno"

La Interacción del usuario define si la vulnerabilidad requiere primero de la acción de un usuario interno que use el sistema para que se abra la puerta al ataque, ya sea clicando un enlace en un mail, descargando un archivo etc. En este caso es "Ninguna"

Todos estos apartados influyen en la puntuación de una vulnerabilidad ya que o bien modifican la superficie de ataque, como puede ser el vector, o condicionan en primer lugar la posibilidad de aparición de esta vulnerabilidad, como puede ser la complejidad y los privilegios requeridos.

A.2.3

Ordena las cuatro vulnerabilidades por prioridad de corrección para DeltaSoft y justifica el orden. ¿Coincide con el orden por CVSS? Ten en cuenta qué equipos están expuestos a Internet y cuáles solo a la red interna.

1- CVE-2024-6387 → SRV_FICHEROS

Al tratarse de una vulnerabilidad a nivel red que permite la ejecución de código, sin autentificación y considerando la información que hay en el servidor y que este está conectado a internet con SSH abierto, me parece la más prioritaria.

2- **CVE-2021-41773 → APP-WEB**

Al tratarse de una vulnerabilidad a nivel de red que permite la navegación entre ficheros del servidor y la ejecución de código en remoto es la segunda más prioritaria en mi opinión ya creo que el servidor en concreto es ligeramente menos importante ya que es el host del aplicativo y no parece tener datos sensibles.

3 - **CVE-2020-11023 → APP-WEB**

Al tratarse de una vulnerabilidad a nivel de red que permite la ejecución de código JQuery sin autentificación y considerando que el servidor está expuesto a internet (Aunque solo a través del puerto del protocolo HTTP) una vez más, aunque la vulnerabilidad es de prioridad alta, el servidor no contiene datos sensibles así que no me parece tan prioritaria.

4 - CVE-2017-0144 → PC_CONTA

Al tratarse de una vulnerabilidad a nivel de red que permite ejecutar código en remoto, la categorización es de ALTA pero a nivel interno, y teniendo en cuenta que el servidor de contabilidad es un equipo desconectado de la red global es el equipo con la menor superficie de ataque y el más protegido a ese respecto, creo que es la menos prioritaria.

A.2.4

Comprueba si alguna de las cuatro figura en el catálogo KEV de CISA (vulnerabilidades explotadas activamente) y explica qué aporta ese dato a la priorización.

Tanto CVE-2017-0144 Como CVE-2021-41773 figuran como vulnerabilidades reconocidas como utilizadas en ataques por el catálogo. Imagino que saber que ya se han realizado este tipo de ataques aprovechando estas vulnerabilidades podría reducir su complejidad ya que puede que los mismos atacantes u otros que hayan podido aprender de estos, repliquen el ataque contra nosotros.

Quizás el caso de CVE-2021-41773, que es de criticidad extrema, ha sido aprovechada previamente e implica ejecutar código en nuestro servidor podría ganar aún más prioridad, pero en mi opinión, el hecho de tener expuesto un equipo a internet a través del mismo protocolo que el caso de la vulnerabilidad CVE-2024-6387 es aún más prioritario.

Además de esto, y sin conocimientos específicos sobre la materia, la solución más inmediata es la de CVE-2021-41773, ya que se trata de un error en nuestra versión específica de Apache Server HTTP, actualizar a versiones superiores (Si bien el NIST menciona que la inmediatamente superior 2.4.50 es una solución incompleta) debería ayudarnos a solventar el problema de manera relativamente rápida.

Parte B · Tu servidor: montaje, reproducción del escenario y auditoría

B.1. Montaje de la máquina virtual

B.1.3

Instala los servicios que tenía el servidor de la empresa: servidor web Apache, servidor FTP vsftpd, Samba y el servidor de bases de datos MariaDB. Documenta los comandos utilizados.

- Instalación de Apache Web Server

```
root@srv-ficheros-nunez:/home/nunez# sudo apt install -y apache2
```

- Arrancar servicio Apache Web Server

```
root@srv-ficheros-nunez:/home/nunez# systemctl enable --now apache2
Synchronizing state of apache2.service with SysV service script with /usr/lib/sy
stemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable apache2
```

```
root@srv-ficheros-nunez:/home/nunez# systemctl status apache2 --no-pager
● apache2.service - The Apache HTTP Server
     Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: e
nabled)
     Active: active (running) since Fri 2026-10-09 10:46:08 CEST; 11min ago
 Invocation: 26adc8d404134e1bb42dd3690affa442
       Docs: https://httpd.apache.org/docs/2.4/
   Main PID: 794 (apache2)
      Tasks: 55 (limit: 2280)
     Memory: 8.7M (peak: 9.2M)
        CPU: 137ms
     CGroup: /system.slice/apache2.service
             ├─794 /usr/sbin/apache2 -k start
             ├─796 /usr/sbin/apache2 -k start
             └─797 /usr/sbin/apache2 -k start

Oct 09 10:46:08 srv-ficheros-nunez systemd[1]: Starting apache2.service - Th….....
Oct 09 10:46:08 srv-ficheros-nunez apachectl[790]: AH00558: apache2: Could n…age
Oct 09 10:46:08 srv-ficheros-nunez systemd[1]: Started apache2.service - The…er.
```

- Instalación de vsftpd:

```
root@srv-ficheros-nunez:/home/nunez# apt install -y vsftpd
```

```
root@srv-ficheros-nunez:/home/nunez# systemctl enable --now vsftpd
Synchronizing state of vsftpd.service with SysV service script with /usr/lib/sys
temd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable vsftpd
root@srv-ficheros-nunez:/home/nunez# systemctl status vsftpd --no-pager
• vsftpd.service - vsftpd FTP server
     Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; enabled; preset: en
abled)
     Active: active (running) since Sat 2026-10-10 16:22:04 CEST; 3min 57s ago
 Invocation: bf120e7f8c7041b09fc12481c98f6d7f
   Main PID: 1190 (vsftpd)
      Tasks: 1 (limit: 2280)
     Memory: 948K (peak: 2M)
        CPU: 14ms
     CGroup: /system.slice/vsftpd.service
             └─1190 /usr/sbin/vsftpd /etc/vsftpd.conf

Oct 10 16:22:04 srv-ficheros-nunez systemd[1]: Starting vsftpd.service - vsf….…
Oct 10 16:22:04 srv-ficheros-nunez systemd[1]: Started vsftpd.service - vsft…er.
Hint: Some lines were ellipsized, use -l to show in full.
root@srv-ficheros-nunez:/home/nunez#
```

- Instalación Samba

```
root@srv-ficheros-nunez:/home/nunez# apt install -y samba_
```

- MariaDB

```
root@srv-ficheros-nunez:/home/nunez# apt install -y mariadb-server
```

B.2. Reproducción del estado inseguro

Añadir usuario admin con contraseña no segura:

```
root@srv-ficheros-nunez:/home/nunez# sudo adduser admin
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for admin
Enter the new value, or press ENTER for the default
        Full Name []:
        Room Number []:
        Work Phone []:
        Home Phone []:
        Other []:
Is the information correct? [Y/n] y
root@srv-ficheros-nunez:/home/nunez# _
```

Sudo para el usuario admin sin contraseña:

```
root@srv-ficheros-nunez:/home/nunez# sudo usermod -aG sudo admin
root@srv-ficheros-nunez:/home/nunez#
```

```
root@srv-ficheros-nunez:/home/nunez# echo "admin ALL=(ALL) NOPASSWD: ALL" | sudo
 tee /etc/sudoers.d/admin
admin ALL=(ALL) NOPASSWD: ALL
root@srv-ficheros-nunez:/home/nunez# _
```

Carpeta de nóminas con permisos para todo el mundo:

```
root@srv-ficheros-nunez:/home/nunez# sudo mkdir -p /srv/nominas
root@srv-ficheros-nunez:/home/nunez# _
```

```
root@srv-ficheros-nunez:/home/nunez# echo "empleado;importe" | sudo tee /srv/nom
inas/nominas_enero.csv
empleado;importe
root@srv-ficheros-nunez:/home/nunez# sudo chmod -R 777 /srv/nominas
root@srv-ficheros-nunez:/home/nunez# _
```

Recurso compartido de Samba sin autenticación:

```
root@srv-ficheros-nunez:/home/nunez# sudo nano /etc/samba/smb.conf
```

```
  GNU nano 8.4                        /etc/samba/smb.conf

# Windows clients look for this share name as a source of downloadable
# printer drivers
[print$]
   comment = Printer Drivers
   path = /var/lib/samba/printers
   browseable = yes
   read only = yes
   guest ok = no
# Uncomment to allow remote administration of Windows print drivers.
# You may need to replace 'lpadmin' with the name of the group your
# admin users are members of.
# Please note that you also need to set appropriate Unix permissions
# to the drivers directory for these users to have write rights in it
;   write list = root, @lpadmin

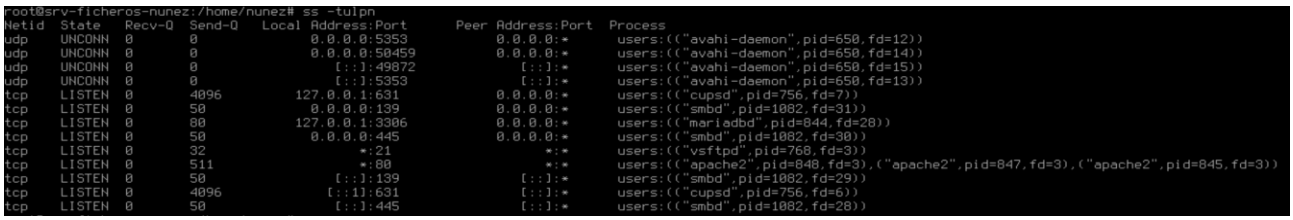
[nominas]
path = /srv/nominas
guest ok = yes
read only = no
_
```

```
root@srv-ficheros-nunez:/home/nunez# sudo systemctl restart smbd
root@srv-ficheros-nunez:/home/nunez# _
```

B.3. Auditoría interna del servidor

B.3.1. Superficie de exposición.

Obtén todos los puertos a la escucha. Para cada uno indica servicio, proceso, si escucha en todas las interfaces o solo en la local, si cifra las comunicaciones y si es necesario para la función del servidor.



- **Proceso “Avahi Daemon”:**

Daemon de Linux que implementa el protocolo zero conf networking, útil para ver sistemas en redes locales. No cifra las conexiones.

Usa los siguientes puertos:

5353, 50459 y 49872 (Todas las interfaces)

- Proceso CUPSD:

Daemon de Linux para la gestión de impresión. No cifra las conexiones ya que el protocolo que emplea (IPP) no es seguro.

Usa el puerto 631 (Solo local).

- Proceso SMBD:

Daemon de SAMBA, que proporciona utilidades para el intercambio de ficheros entre sistemas Windows y Linux en redes heterogéneas. No cifra los datos ya que los protocoles que usa (SMB y CIFS) no son seguros.

Usa el puerto 139 y 445 (Todas las interfaces)

- Proceso mariadbd:

Daemon del servidor SQL de mariadb, por defecto no cifra los datos, salvo que se aplicaran configuraciones TLS.

Usa el puerto 3306 (Solo local).

- Proceso vsftpd:

Daemon del servidor de Very Secure File Transfer Protocol, en principio es seguro ya que permite el uso de protocolos TLS / SSL además de emplear el principio de menor privilegio para todos sus servicios.

Usa el puerto 21 (Todas las interfaces).

- Proceso apache2:

Daemon del servidor host web de apache, no es cifrado ya que emplea el protocolo http que no es seguro.

Usa el puerto 80 (Todas las interfaces).

B.3.2. Versiones y parches.

Las versiones instaladas en mi servidor son:

```
root@srv-ficheros-nunez:/home/nunez# dpkg -l | grep -E 'ssh|apache2|samba|vsftpd|mariadb-server'
ii  apache2                                2.4.68-1~deb13u1                    amd64        Apache HTTP Server
ii  apache2-bin                            2.4.68-1~deb13u1                    amd64        Apache HTTP Server (modules and other binary files)
ii  apache2-data                           2.4.68-1~deb13u1                    all          Apache HTTP Server (common files)
ii  apache2-utils                          2.4.68-1~deb13u1                    amd64        Apache HTTP Server (utility programs for web servers)
ii  libapache2-mod-dnssd                   0.6-5                               amd64        Zeroconf support for Apache 2 via avahi
ii  libldb2:amd64                          2:2.11.0+samba4.22.11+dfsg-0+deb13u1 amd64       LDAP-like embedded database - shared library
ii  libssh-4:amd64                         0.11.5-0+deb13u1                    amd64        tiny C SSH library (OpenSSL flavor)
ii  libssh2-1t64:amd64                     1.11.1-1+deb13u2                    amd64        SSH2 client-side library
ii  libtalloc2:amd64                       2:2.4.3+samba4.22.11+dfsg-0+deb13u1  amd64       hierarchical pool based memory allocator
ii  libtdb1:amd64                          2:1.4.13+samba4.22.11+dfsg-0+deb13u1 amd64       Trivial Database - shared library
ii  libtevent0t64:amd64                    2:0.16.2+samba4.22.11+dfsg-0+deb13u1 amd64       talloc-based event loop library - shared library
ii  mariadb-server                         1:11.8.6-0+deb13u1                  amd64        MariaDB database server binaries
ii  mariadb-server-core                    1:11.8.6-0+deb13u1                  amd64        MariaDB database core server files
ii  openssh-client                         1:10.0p1-7+deb13u4                  amd64        secure shell (SSH) client, for secure access to remote machines
ii  python3-ldb                            2:2.11.0+samba4.22.11+dfsg-0+deb13u1 amd64       Python 3 bindings for LDB
ii  python3-samba                          2:4.22.11+dfsg-0+deb13u1            amd64        Python 3 bindings for Samba
ii  python3-talloc:amd64                   2:2.4.3+samba4.22.11+dfsg-0+deb13u1  amd64       hierarchical pool based memory allocator - Python3 bindings
ii  python3-tdb                            2:1.4.13+samba4.22.11+dfsg-0+deb13u1 amd64       Python3 bindings for TDB
ii  samba                                  2:4.22.11+dfsg-0+deb13u1            amd64        SMB/CIFS file, print, and login server for Unix
ii  samba-ad-dc                            2:4.22.11+dfsg-0+deb13u1            amd64        Samba control files to run AD Domain Controller
ii  samba-ad-provision                     2:4.22.11+dfsg-0+deb13u1            all          Samba files needed for AD domain provision
ii  samba-common                           2:4.22.11+dfsg-0+deb13u1            all          common files used by both the Samba server and client
ii  samba-common-bin                       2:4.22.11+dfsg-0+deb13u1            amd64        Samba common files used by both the server and the client
ii  samba-dsdb-modules:amd64               2:4.22.11+dfsg-0+deb13u1            amd64        Samba Directory Services Database
ii  samba-libs:amd64                       2:4.22.11+dfsg-0+deb13u1            amd64        Samba core libraries
ii  tdb-tools                              2:1.4.13+samba4.22.11+dfsg-0+deb13u1 amd64       Trivial Database - bundled binaries
ii  vsftpd                                 3.0.5-0.2                           amd64        lightweight, efficient FTP server written for security
root@srv-ficheros-nunez:/home/nunez#
```

Apache2 – 2.4.68, MariaDB – 11.8.6 , OpenSSH – 10.0p1-7

Samba – 4.22.11, vsftpd – 3.0.5

La lista de actualizaciones pendientes no me informa de ninguna actualización sobre los paquetes de estas funcionalidades descritas, creo que he instalado por defecto las últimas versiones de cada una por desconocimiento y no consigo hacer rollback a la réplica de las versiones del servidor original.

```
root@srv-ficheros-nunez:/home/nunez# apt update
Hit:1 http://deb.debian.org/debian trixie InRelease
Get:2 http://security.debian.org/debian-security trixie-security InRelease [43.4 kB]
Get:3 http://deb.debian.org/debian trixie-updates InRelease [47.3 kB]
Get:4 http://security.debian.org/debian-security trixie-security/main Sources [240 kB]
Get:5 http://security.debian.org/debian-security trixie-security/main amd64 Packages [266 kB]
Get:6 http://security.debian.org/debian-security trixie-security/main Translation-en [163 kB]
Fetched 760 kB in 0s (3,957 kB/s)
13 packages can be upgraded. Run 'apt list --upgradable' to see them.
root@srv-ficheros-nunez:/home/nunez# apt list --upgradable
ghostscript/stable-security 10.05.1~dfsg-1+deb13u3 amd64 [upgradable from: 10.05.1~dfsg-1+deb13u2]
gir1.2-javascriptcoregtk-4.1/stable-security 2.54.0-1~deb13u2 amd64 [upgradable from: 2.52.6-1~deb13u1]
gir1.2-webkit2-4.1/stable-security 2.54.0-1~deb13u2 amd64 [upgradable from: 2.52.6-1~deb13u1]
libgs-common/stable-security 10.05.1~dfsg-1+deb13u3 all [upgradable from: 10.05.1~dfsg-1+deb13u2]
libgs10-common/stable-security 10.05.1~dfsg-1+deb13u3 all [upgradable from: 10.05.1~dfsg-1+deb13u2]
libgs10/stable-security 10.05.1~dfsg-1+deb13u3 amd64 [upgradable from: 10.05.1~dfsg-1+deb13u2]
libjavascriptcoregtk-4.1-0/stable-security 2.54.0-1~deb13u2 amd64 [upgradable from: 2.52.6-1~deb13u1]
libjavascriptcoregtk-6.0-1/stable-security 2.54.0-1~deb13u2 amd64 [upgradable from: 2.52.6-1~deb13u1]
liblzma5/stable-security 5.8.1-1+deb13u2 amd64 [upgradable from: 5.8.1-1+deb13u1]
libpng16-16t64/stable-security 1.6.48-1+deb13u6 amd64 [upgradable from: 1.6.48-1+deb13u5]
libwebkit2gtk-4.1-0/stable-security 2.54.0-1~deb13u2 amd64 [upgradable from: 2.52.6-1~deb13u1]
libwebkitgtk-6.0-4/stable-security 2.54.0-1~deb13u2 amd64 [upgradable from: 2.52.6-1~deb13u1]
xz-utils/stable-security 5.8.1-1+deb13u2 amd64 [upgradable from: 5.8.1-1+deb13u1]
root@srv-ficheros-nunez:/home/nunez# _
```

Aun así y describiendo el backporting:

Debian mantiene una versión estable y, cuando se descubre una vulnerabilidad, corrige el fallo en esa misma versión en lugar de subir a la versión nueva del autor. Por esto, un paquete de OpenSSH con la versión 9.2p1 por ejemplo, puede estar parcheado y no ser vulnerable, y lo único que cambia es el sufijo de Debian. Por eso hay que mirar la versión completa del paquete y compararla con la que marca el Security Tracker como corregida, no solo el número principal que corresponde con la versión del autor.

B.3.3. Cuentas y privilegios.

Usuarios con login activo:

```
root@srv-ficheros-nunez:/home/nunez# getent passwd | grep -vE 'nologin|/bin/false|/usr/sbin/nologin'
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
luque:x:1000:1000:luque,,,:/home/luque:/bin/bash
nunez:x:1001:1001:,,,:/home/nunez:/bin/bash
admin:x:1002:1002:,,,:/home/admin:/bin/bash
root@srv-ficheros-nunez:/home/nunez# _
```

Usuarios del grupo sudo:

```
root@srv-ficheros-nunez:/home/nunez# getent group sudo
sudo:x:27:luque,nunez,admin
root@srv-ficheros-nunez:/home/nunez# _
```

Permisos de los usuarios del grupo sudo (Ejemplo para mi usuario):

```
root@srv-ficheros-nunez:/home/nunez# sudo -l -u nunez
usage: sudo -h | -K | -k | -V
usage: sudo -v [-ABkNnS] [-g group] [-h host] [-p prompt] [-u user]
usage: sudo -l [-ABkNnS] [-g group] [-h host] [-p prompt] [-U user]
            [-u user] [command [arg ...]]
usage: sudo [-ABbEHkNnPS] [-r role] [-t type] [-C num] [-D directory]
            [-g group] [-h host] [-p prompt] [-R directory] [-T timeout]
            [-u user] [VAR=value] [-i | -s] [command [arg ...]]
usage: sudo -e [-ABkNnS] [-r role] [-t type] [-C num] [-D directory]
            [-g group] [-h host] [-p prompt] [-R directory] [-T timeout]
            [-u user] file ...
root@srv-ficheros-nunez:/home/nunez# _
```

Permiso de sudo sin contraseña:

```
root@srv-ficheros-nunez:/home/nunez# grep -rn "NOPASSWD" /etc/sudoers /etc/sudoers.d/
/etc/sudoers.d/admin:1:admin ALL=(ALL) NOPASSWD: ALL
root@srv-ficheros-nunez:/home/nunez#
```

B.3.4. Permisos y recursos compartidos.

Los directorios en los que cualquier usuario puede modificar sin permiso son:

```
root@srv-ficheros-nunez:/home/nunez# find / -xdev -type f -perm -0002 2>/dev/null
/srv/nominas/nominas_enero.csv
root@srv-ficheros-nunez:/home/nunez#
```

Los recursos compartidos de Samba sin autenticación son:

```
Loaded services file OK.
Weak crypto is allowed by GnuTLS (e.g. NTLM as a compatibility fallback)

WARNING: The 'netbios name' is too long (max. 15 chars).

Server role: ROLE_STANDALONE

# Global parameters
[global]
        log file = /var/log/samba/log.%m
        logging = file
        map to guest = Bad User
        max log size = 1000
        obey pam restrictions = Yes
        pam password change = Yes
        panic action = /usr/share/samba/panic-action %d
        passwd chat = *Enter\snew\s*\spassword:* %n\n *Retype\snew\s*\spassword:* %n\n *password\supdated\ssuccessfully* .
        passwd program = /usr/bin/passwd %u
        server role = standalone server
        unix password sync = Yes
        usershare allow guests = Yes
        idmap config * : backend = tdb


[homes]
        browseable = No
        comment = Home Directories
        create mask = 0700
        directory mask = 0700
        valid users = %S


[printers]
        browseable = No
        comment = All Printers
        create mask = 0700
        path = /var/tmp
        printable = Yes


[print$]
        comment = Printer Drivers
        path = /var/lib/samba/printers


[nominas]
        guest ok = Yes
        path = /srv/nominas
        read only = No
```

El guest ok permite el acceso al recurso sin autenticación.

B.3.5. Configuraciones por defecto.

Las configuraciones por defecto del SSH server son:

```
port 22
listenaddress [::]:22
listenaddress 0.0.0.0:22
maxauthtries 6
permitrootlogin without-password
passwordauthentication yes
permitemptypasswords no
gatewayports no
root@srv-ficheros-nunez:/home/nunez#
```

Las configuraciones por defecto de vsftpd son:

```
root@srv-ficheros-nunez:/home/nunez# grep -vE '^\s*#|^\s*$' /etc/vsftpd.conf
listen=NO
listen_ipv6=YES
anonymous_enable=NO
local_enable=YES
dirmessage_enable=YES
use_localtime=YES
xferlog_enable=YES
connect_from_port_20=YES
secure_chroot_dir=/var/run/vsftpd/empty
pam_service_name=vsftpd
rsa_cert_file=/etc/ssl/certs/ssl-cert-snakeoil.pem
rsa_private_key_file=/etc/ssl/private/ssl-cert-snakeoil.key
ssl_enable=NO
root@srv-ficheros-nunez:/home/nunez# _
```

Las políticas de cambio de contraseña para admin, por ejemplo, son:

```
root@srv-ficheros-nunez:/home/nunez# chage admin --list
Last password change                                    : Oct 10, 2026
Password expires                                        : never
Password inactive                                       : never
Account expires                                         : never
Minimum number of days between password change          : 0
Maximum number of days between password change          : 99999
Number of days of warning before password expires       : 7
root@srv-ficheros-nunez:/home/nunez#
```

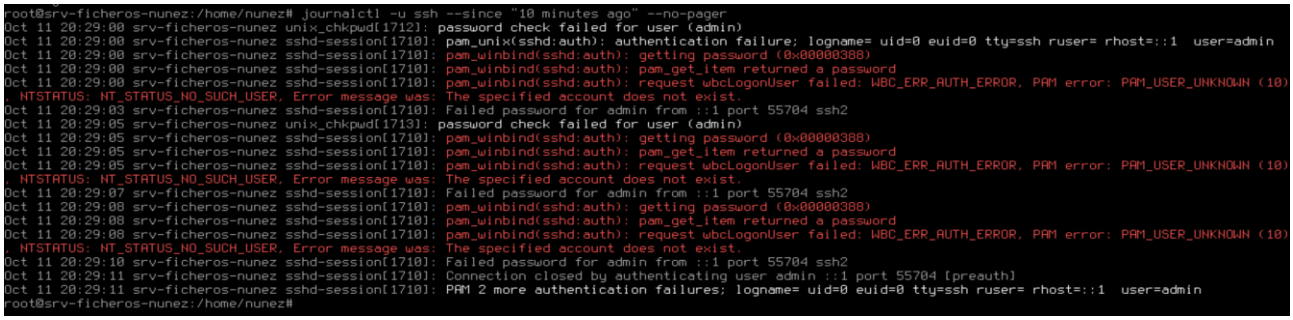
Respecto a los cortafuegos:

```
root@srv-ficheros-nunez:/home/nunez# nft list ruleset
root@srv-ficheros-nunez:/home/nunez# systemctl status nftables
● nftables.service - nftables
     Loaded: loaded (/usr/lib/systemd/system/nftables.service; disabled; preset: enabled)
     Active: inactive (dead)
       Docs: man:nft(8)
             http://wiki.nftables.org
root@srv-ficheros-nunez:/home/nunez# _
```

El servicio de cortafuegos está activo pero no se listan ninguna regla que se esté ejectutando.

B.3.6. Así se ve un ataque en los registros.

Tras comprobar el journaltcl:



Desde luego el fichero de log que tenemos para el ejercicio C parece más conciso y claro que el mensaje que obtengo en mi máquina, ya que este describe el nombre de usuario, la ipv4 pública (Parece y entiendo porque en principio deltasoft no tiene VPN) el puerto y el protocolo (ssh2).

Parte C · Análisis de evidencias: ¿está comprometido el sistema?

C.1. Identificar las señales de actividad sospechosa:

- 2027-13-01, 18:05:10 / web_access.log

Intento de inyección SQL para saltarse la autenticación, a nivel de red.

- 2027-13-01, 18:05:44 / web_access.log

Uso de <script> que envia un document.cookie, es un intento de cross site scripting para robar cookies de sesión. Nivel de red.

- 2027-13-01, 18:06:20 / web_access.log

“id=105 UNION SELECT usuario,clave FROM usuarios”. Es una clara **inyección SQL** para extraer credenciales. A nivel de red

- 2027-14-01, 02:20:11 -> 02:20:14 / cortafuegos.log

Escaneo de puertos abiertos típicos de servicio, 22 para ssh, 80 para http, 443 para https, 8080 para alt-http entre otros. Aparece a nivel red ya que surgen desde una ip pública y además, al probar tantos en tan poco tiempo, parece automatizado.

Indica bajo mi punto de vista un sondeo de posibles puntos de ataque.

- 2027-14-01, 02:31:02 -> 02:37:00 / cortafuegos.log

UT1 – Práctica 1.

Intentos de conexión automatizada a través del puerto 22 del SSH, apunta a fuerza bruta, supongo. Nivel de red

- 2027-14-01, 02:31:02 -> 02:37:00 / servidor_auth.log

sshd emite errores de contraseña fallida para múltiples usuarios de nombres fáciles, todos con diferentes puertos, diferentes nombres pero siempre desde la misma ipv4. Nivel de red

Apunta a un intento de login por fuerza bruta, empleando contraseñas fáciles reconocidas.

- 2027-14-01, 02:38:55 / servidor_auth.log

Login correcto sobre el usuario admin, se abre sesión, se crea el usuario **svc_update, se le añade a sudo.** Nivel de sistema.

Escalada de privilegios y persistencia, ya tienen un usuario en el sistema con permisos elevados.

- 2027-14-01, 02:39:20 +- / servidor_auth.log y servidor_sistema.log

Se desactiva “clamav-daemon”, lanzado como root. Evasión de defensas, a nivel de Sistema.

- 2027-14-01 02:43:11 / servidor_sistema.log

Proceso kworker-9x lanzado como root desde /tmp/.cache/. Al parecer este término se usa como nombre genérico para los hilos de trabajo kernel de Linux, por lo que es una actividad maliciosa, probablemente malware camuflado por un proceso normal de sistema que se ejecuta desde un directorio tempora. A nivel de sistema.

- 2027-14-01 02:43:12 / servidor_sistema.log

Uso de cpu elevado, sostenido durante 11 minutos, podría indicar el cifrado del archivo que se pretende atacar o algún otro tipo de actividad maliciosa, minería obtención de datos etc… A nivel de sistema.

- 2027-14-01 02:50:01 / servidor_sistema.log

Se crea una tarea de cron asociada al usuario también creado recientemente (SVC_UPDATE) cron es el ejecutador automático de tareas de Linux, podría indicar una tarea tipo beacon para que el atacante mantenga una verificación fácil de comunicación con el servidor. A nivel de sistema.

- 2027-14-01 02:54:02 / servidor_sistema.log

3412 archivos modificados en /home y /srv/nominas, pasan a extensión .lockx ahora está claro que es un ramsonware. A nivel de sistema.

- 2027-14-01 02:55:00 / servidor_sistema.log

Aparece el fichero de texto LEEME_REESCATE.txt en el directorio de nóminas, aquí seguramente encontraremos las condiciones del rescate de nuestros datos cifrados.

A nivel de sistema.

- 2027-14-01, 02:56:40…03:01:40… / cortafuegos.log

Se detectan conexiones salientes cada 5 minutos camufladas como llamadas http (Por el puerto 443), corresponden a la tarea cron de Beaconing, e irán contra el servidor que use el atacante para comprobación de la conexión activa contra el servidor atacado. A nivel de red.

C.2. Reconstrucción cronológica y relación con apartado B:

Hora	Evento	Fase
13/01 18:04	Ataques SQLi y XSS contra APP-WEB desde 203.0.113.88	Reconocimiento y explotación de la aplicación web, con posible obtención de credenciales
14/01 02:20	Escaneo de 1.024 puertos	Reconocimiento
02:31-02:37	Fuerza bruta por SSH	Explotación (acceso por credenciales)
02:37:41	Login correcto como admin	Acceso inicial conseguido
02:38:55-56	Crea svc_update y la mete en sudo	Persistencia y escalada de privilegios
02:39:20	Apaga ClamAV	Evasión de defensas
02:43	Ejecuta kworker-9x como root	Instalación y ejecución del malware
02:50	Cron con beaconizado	Persistencia y establecimiento de C2.
02:54-02:55	Cifrado de /home y /srv/nominas, nota de rescate	Acciones sobre el objetivo (impacto)
02:56 en adelante	Beaconing cada 5 min a 198.51.100.23	Conexión con el C2.

Hallazgo en B	Qué parte del ataque explica
SSH expuesto a Internet (B.3.1)	Escaneo y la fuerza bruta desde fuera
PasswordAuthentication yes, MaxAuthTries alto, ausencia de bloqueo (B.3.5)	Hicieron posibles los 1.184 intentos.
Contraseña débil de admin y sin caducidad (PASS_MAX_DAYS 99999) (B.3.5)	Explica que el ataque de fuerza bruta funcionase
admin en el grupo sudo con regla NOPASSWD (B.3.3)	Explica los useradd, usermod y systemctl como root sin pedir contraseña
Sin reglas nft en el host (B.3.5)	No había filtrado local ni de salida, y el C2 pudo comunicarse
/tmp con ejecución y permisos amplios (B.3.4)	Permitió lanzar el malware desde /tmp/.cache/

C.3. APP-WEB, ataques reconocidos:

1. Inyección SQL (SQLi):

- “usuario=admin' --“: la comilla cierra la cadena y “--“ comenta el resto de la consulta SQL. La respuesta 302 y el acceso al panel con código 200 indican que el acceso fue correcto.
- “id=105 UNION SELECT usuario,clave FROM usuarios”: añade una segunda consulta para volcar usuarios y claves. La respuesta 200 sugiere que la consulta devolvió datos.

Debilidad: las entradas se concatenan directamente en la consulta SQL, sin sentencias parametrizadas.

2. Cross-Site Scripting:

El parámetro q de buscar.php incluye un <script> que envía document.cookie supongo que para un intento de robo de cookies para suplantar la sesión de otro usuario.

Debilidad: la aplicación refleja la entrada sin codificar la salida, puede que se deba al uso del protocolo http en lugar de https.

C.4. Clasificación:

El incidente es Externo y al parecer dirigido, es un ataque que procede de un ciber delincuente ya que emplea utilidades de escaneo automatizado y fuerza bruta, y claramente para tener como objetivo obtener una compensación económica, un acto de Ransomware prácticamente de manual.

Impacto CIA:

- **Confidencialidad:** Afectada. Se pueden haber extraído credenciales de la web y cookies así como datos personales, y el beaconing deja abierta la posible nueva filtración de nóminas.
- **Integridad:** Muy afectada. Hay miles de archivos cifrados, una cuenta nueva con sudo, el antivirus apagado y un sistema comprometido como root, por lo que ya no es fiable.
- **Disponibilidad:** Muy afectada. Los datos ahora son inaccesibles y el servidor mantiene malware en ejecución.

Consecuencias:

Económicas: Se da la necesidad inmediata de parar la actividad hasta la resolución de esta incidencia. Coste de análisis, restauración, rescate…

Legales: Como el archivo nóminas contiene datos personales de nuestros empleados, números de teléfono, correos, nombres, DNI… Es probable que haya que notificar a la Agencia Española de Protección de Datos o recaerán sanciones.

Reputacionales: Pérdida de la confianza de clientes, empleados y proveedores.

Operativas: Imposibilidad de gestionar nóminas.

C.4. Medidas:

Medida concreta	¿Qué corrige?
Cerrar SSH a Internet y acceder solo por VPN. Autenticación por clave, limitar el número de intentos de login.	SSH expuesto, contraseña permitida, intentos ilimitados
Mínimo privilegio: Eliminar la regla NOPASSWD, quitar admin de sudo, usar cuentas nominales y MFA, exigir contraseñas robustas con caducidad.	NOPASSWD, política de contraseñas
Firewall de host con nftables: denegar por defecto, limitar conexiones por origen y **filtrar el tráfico saliente**, para que el servidor no pueda contactar con un C2.	Sin reglas de firewall
Cambio a HTTPS.	Intento de robo de cookies.